

TD2 : évaluation des niveaux de risques

Objectif : En fonction des vulnérabilités décrites, vous devez déterminer le niveau de risque adapté en fonction de la facilité d'exploitation et de l'impact (selon votre estimation et sans connaître l'identifiant CVE). N'hésitez pas à faire des recherches Google si vous ne comprenez pas certains termes techniques.

Utiliser la notation ANSSI (référentiel d'exigences [PASSI](#)) suivante :

Facilité d'exploitation Impact	Difficile	Elevée	Modérée	Facile
Mineur	Mineur	Mineur	Important	Majeur
Important	Mineur/Important ⁹	Important	Important	Majeur
Majeur	Important	Majeur	Majeur	Critique
Critique	Important	Majeur	Critique	Critique

Plus de détails sur les différents niveaux à la fin du TD, en annexe.

Vuln 1

Mozilla developers and community members reported memory safety bugs present in Firefox 65, Firefox ESR 60.5, and Thunderbird 60.5. Some of these bugs showed evidence of memory corruption and we presume that with enough effort that some of these could be exploited to run arbitrary code. This vulnerability affects Thunderbird < 60.6, Firefox ESR < 60.6, and Firefox < 66.

Facilité d'exploitation	Impact	Niveau de risque
Difficile	Critique	Important

Explication :

Il faut créer un fichier HTML qui contient du Javascript qui va exploiter le navigateur Firefox.

Vuln 2

Survey King v0.3.0 does not filter data properly when exporting excel files, allowing attackers to execute arbitrary code or access sensitive information via a CSV injection attack.

Facilité d'exploitation	Impact	Niveau de risque
Facile	Critique	Critique

Explication :

Un fichier CSV est très facile à créer.

Vuln 3

Vulnerability in the Oracle Java SE, Oracle GraalVM Enterprise Edition product of Oracle Java SE (component: Serialization). Supported versions that are affected are Oracle Java SE: 7u321, 8u311, 11.0.13, 17.01; Oracle GraalVM Enterprise Edition: 20.3.4 and 21.3.0. Difficult to exploit vulnerability allows unauthenticated attacker with network access via multiple protocols to compromise Oracle Java SE, Oracle GraalVM Enterprise Edition. Successful attacks of this vulnerability can result in unauthorized update, insert or delete access to some of Oracle Java SE, Oracle GraalVM Enterprise Edition accessible data. Note: This vulnerability applies to Java deployments, typically in clients running sandboxed Java Web Start applications or sandboxed Java applets, that load and run untrusted code (e.g., code that comes from the internet) and rely on the Java sandbox for security. This vulnerability can also be exploited by using APIs in the specified Component, e.g., through a web service which supplies data to the APIs.

Facilité d'exploitation	Impact	Niveau de risque
Difficile	Critique	Important

Explication :

Successful attacks of this vulnerability can result in unauthorized update, insert or delete access to some of Oracle Java SE, Oracle GraalVM Enterprise Edition accessible data

Vuln 4

In PHP versions 7.4.x below 7.4.28, 8.0.x below 8.0.16, and 8.1.x below 8.1.3, when using filter functions with FILTER_VALIDATE_FLOAT filter and min/max limits, if the filter fails, there is a possibility to trigger use of allocated memory after free, which can result it crashes, and potentially in overwrite of other memory chunks and RCE. This issue affects: code that uses FILTER_VALIDATE_FLOAT with min/max limits.

Facilité d'exploitation	Impact	Niveau de risque
Difficile	Critique	Important

Explication :

|

Il faut faire une corruption mémoire en PHP.

Vuln 5

Apache Log4j2 2.0-beta9 through 2.15.0 (excluding security releases 2.12.2, 2.12.3, and 2.3.1) JNDI features used in configuration, log messages, and parameters do not protect against attacker controlled LDAP and other JNDI related endpoints. An attacker who can control log messages or log message parameters can execute arbitrary code loaded from LDAP servers when message lookup substitution is enabled. From log4j 2.15.0, this behavior has been disabled by default. From version 2.16.0 (along with 2.12.2, 2.12.3, and 2.3.1), this functionality has been completely removed. Note that this vulnerability is specific to log4j-core and does not affect log4net, log4cxx, or other Apache Logging Services projects.

Facilité d'exploitation	Impact	Niveau de risque
Facile	Critique	Critique

Explication :

Une seule chaine de caractères permet d'exploiter cette vulnérabilité.

Vuln 6

Multiple versions of GARO Wallbox GLB/GTB/GTC are affected by hard coded credentials. A hardcoded credential exist in /etc/tomcat8/tomcat-user.xml, which allows attackers to gain authorized access and control the tomcat completely on port 8000 in the tomcat manger page.

Facilité d'exploitation	Impact	Niveau de risque
Facile	Critique	Critique

Explication :

Mots de passe en dur dans un fichier.

Vuln 7

Authenticated (admin or higher user role) Stored Cross-Site Scripting (XSS) vulnerability discovered in AMP for WP – Accelerated Mobile Pages WordPress plugin (versions <= 1.0.77.31).

Facilité d'exploitation	Impact	Niveau de risque
Modérée	Majeur	Majeur

Explication :

Il faut déjà avoir un compte pour exploiter le XSS.

Vuln 8

IBM Cognos Controller 10.4.0, 10.4.1, and 10.4.2 is vulnerable to an XML External Entity Injection (XXE) attack when processing XML data. A remote attacker could exploit this vulnerability to expose sensitive information or consume memory resources.

Facilité d'exploitation	Impact	Niveau de risque
Facile	Majeur	Critique

Explication :

|
| Très simple d'utiliser un fichier XML malveillant dans un programme.
|

Vuln 9

A race condition was found in the Linux kernel's ebf verifier between bpf_map_update_elem and bpf_map_freeze due to a missing lock in kernel/bpf/syscall.c. In this flaw, a local user with a special privilege (cap_sys_admin or cap_bpf) can modify the frozen mapped address space. This flaw affects kernel versions prior to 5.16 rc2.

Facilité d'exploitation	Impact	Niveau de risque
Difficile	Critique	Important

Explication :

|
| Race condition difficile car il faut exécuter en même temps plusieurs programmes.
|

Vuln 10

Deserialization of untrusted data in Veeam Agent for Windows 2.0, 2.1, 2.2, 3.0.2, 4.x, and 5.x allows local users to run arbitrary code with local

system privileges.

Facilité d'exploitation	Impact	Niveau de risque
Elevée	Critique	Majeur

Explication :

Exploiter une désérialisation est difficile. En plus, il faut être déjà connecté à la

Annexe : Echelle de classification des vulnérabilités

L'ANSSI propose l'échelle de classification des vulnérabilités suivante.

Les vulnérabilités, qu'elles soient d'origine technique ou organisationnelle, sont classées en fonction du risque qu'elles font peser sur le système d'information, c'est-à-dire en fonction de l'impact de la vulnérabilité sur le système d'information et de sa difficulté d'exploitation.

Le niveau du risque lié à chaque vulnérabilité est apprécié selon l'échelle de valeur suivante :

- **Mineur** : faible risque sur le système d'information et pouvant nécessiter une correction ;
- **Important** : risque modéré sur le système d'information et nécessitant une correction à moyen terme ;
- **Majeur** : risque majeur sur le système d'information nécessitant une correction à court terme ;
- **Critique** : risque critique sur le système d'information et nécessitant une correction immédiate ou imposant un arrêt immédiat du service.

La facilité d'exploitation correspond au niveau d'expertise et aux moyens nécessaires à la réalisation de l'attaque. Elle est appréciée selon l'échelle suivante :

- **Facile** : exploitation triviale, sans outil particulier ;
- **Modérée** : exploitation nécessitant des techniques simples et des outils disponibles publiquement ;
- **Elevée** : exploitation de vulnérabilités publiques nécessitant des compétences en sécurité des systèmes d'information et le développement d'outils simples ;
- **Difficile** : exploitation de vulnérabilités non publiées nécessitant une expertise en sécurité des systèmes d'information et le développement d'outils spécifiques et ciblés.

L'impact correspond aux conséquences que l'exploitation de la vulnérabilité peut entraîner sur le système d'information de l'audité. Il est apprécié selon l'échelle

suivante :

- **Mineur** : pas de conséquence directe sur la sécurité du système d'information audité ;
- **Important** : conséquences isolées sur des points précis du système d'information audité ;
- **Majeur** : conséquences restreintes sur une partie du système d'information audité ;
- **Critique** : conséquences généralisées sur l'ensemble du système d'information audité.